INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

GRC 103 - Week 2 Lab Assignment

Risk Assessment and Management Techniques

Lab 3B: Advanced Cybersecurity Risk Quantification and Control Investment Analysis

Name	Adeshola Oluwole
Registration Number	C1126CGRCE17211
Course	**GRC 103 Risk Assessment and Management Techniques**
Module	**Module 2 — Risk Analysis and Evaluation**
Opens	25 October 2026, 5:41 PM WAT
Due	01 November 2026, 11:59 PM WAT

1. Introduction

A GRC professional is expected to be able to translate technical vulnerabilities into business impact. This lab is a challenge to perform end-to-end risk analysis for a critical business system.

Scenario

You are the lead GRC analyst at "SecureBank Financial." The CISO has provided you with data from a recent penetration test and vulnerability assessment of your new mobile banking platform. Your task is to quantify the financial risk, evaluate control options, and prepare an executive briefing.

2. Objectives

- Calculate risk exposure using quantitative methods
- Perform cost-benefit analysis for security controls
- Create data-driven recommendations
- Develop executive-level risk reporting with visualizations

3. Deliverables

Submit the following completed items:

1. **Completed Risk Calculations**
    - ALE for all vulnerabilities
    - Risk prioritization matrix
2. **Control Analysis Worksheet**
    - Cost-benefit analysis for each control
    - ROI calculations
3. **Graphical Representations**
    - Risk exposure chart (Bar/Pie)
    - Control effectiveness comparison (Scatter Plot)
    - ROI visualization (Horizontal Bar Chart)
    - Risk reduction timeline (Line Graph)

- Investment breakdown (Stacked Bar Chart)
- Risk heat map (Matrix Visualization)

4. **Executive Briefing Package**
    - One-page dashboard with integrated visuals
    - Risk treatment plan with Gantt chart
    - Financial justification with graphs

Graph Requirements:

- All graphs must have proper titles, axis labels, and legends
- Use appropriate colors for different risk levels
- Ensure all financial figures are properly formatted
- Graphs must be professional and executive-ready

4. Lab Data Set

Dataset: Mobile Banking Platform Assessment

System Context:

- Platform: "SecureMobile" banking application
- User Base: 500,000 active customers
- Average Transaction: $2,500
- Daily Transactions: 50,000

Vulnerability Assessment Results:

Critical Finding 1: API Authentication Bypass

- Exploit Probability: 15%
- Systems Affected: Transaction processing system
- Potential Impact: Unauthorized fund transfers
- Maximum Single Incident Loss: $5,000,000
- Estimated Detection: 48 hours

Critical Finding 2: Database Injection Vulnerability

- Exploit Probability: 25%
- Systems Affected: Customer database
- Potential Impact: Data breach (PII + financial data)
- Records at Risk: 500,000 customer profiles
- Cost per Record: $250 (regulatory + notification)

Critical Finding 3: Session Hijacking

- Exploit Probability: 40%
- Systems Affected: User sessions
- Potential Impact: Account takeover
- Accounts at Risk: 5,000 simultaneous sessions
- Average Loss per Account: $1,500

Control Options:

1. **Advanced API Security Gateway**
    - Cost: $350,000
    - Effectiveness: 90% reduction in API vulnerabilities
    - Maintenance: $50,000/year
2. **Web Application Firewall (WAF)**
    - Cost: $150,000
    - Effectiveness: 75% reduction in web vulnerabilities
    - Maintenance: $25,000/year
3. **Multi-Factor Authentication Enhancement**
    - Cost: $200,000
    - Effectiveness: 95% reduction in account takeover
    - Maintenance: $30,000/year

PHASE 1: Risk Exposure Calculation

Task 1: Calculate Annualized Loss Expectancy (ALE)

For each vulnerability, calculate:

- Single Loss Expectancy (SLE)
- Annual Rate of Occurrence (ARO)
- Annualized Loss Expectancy (ALE)

Vulnerability	How SLE is built	SLE	ARO	ALE (SLE x ARO)
API Authentication Bypass	Max single-incident loss is given as $5m	$5,000,000	0.15	$750,000
Database Injection	500,000 records x $250 cost per record	$125,000,000	0.25	$31,250,000
Session Hijacking	$5,000 accounts x $1,500 average loss per account	$7,500,000	0.40	$3,000,000
TOTAL				**$35,000,000**

From the above, the formulas are:

SLE = The loss from one incident

ARO = How many times per yea its expected to happen

ALE = SLE X ARO

Note: From the lab, we have been given “exploit probability but no frequency, so each percentage will be treated as the probability of the event happening once in a year which makes the ARO equal to the probability as 0.15, 0.25 and 0.40.

Task 2: Prioritize Risks

Create a risk matrix showing:

- Vulnerability
- SLE
- ARO
- ALE

Risk Priority Matrix (Task 2): Sorted by ALE, highest first

Rank	Vulnerability	SLE ($)	ARO	ALE ($)	% of Total ALE	Heat Map Rating	Risk Priority Level
1	Database Injection Vulnerability	$125,000,000	0.25	**$31,250,000**	89.3%	**High**	**Critical**
2	Session Hijacking	$7,500,000	0.40	**$3,000,000**	8.6%	**High**	**High**
3	API Authentication Bypass	$5,000,000	0.15	**$750,000**	2.1%	**Medium**	**Medium**

Rating logic

Priority Level (by ALE): Critical >= $10,000,000; High >= $1,000,000; Medium >= $250,000; otherwise Low.
Heat Map Rating (by probability x impact): score = P score x I score; High if score >= 6, Medium if 2 to 5, Low if 1 (bands set in Assumptions).

Task 3: Create Risk Visualization

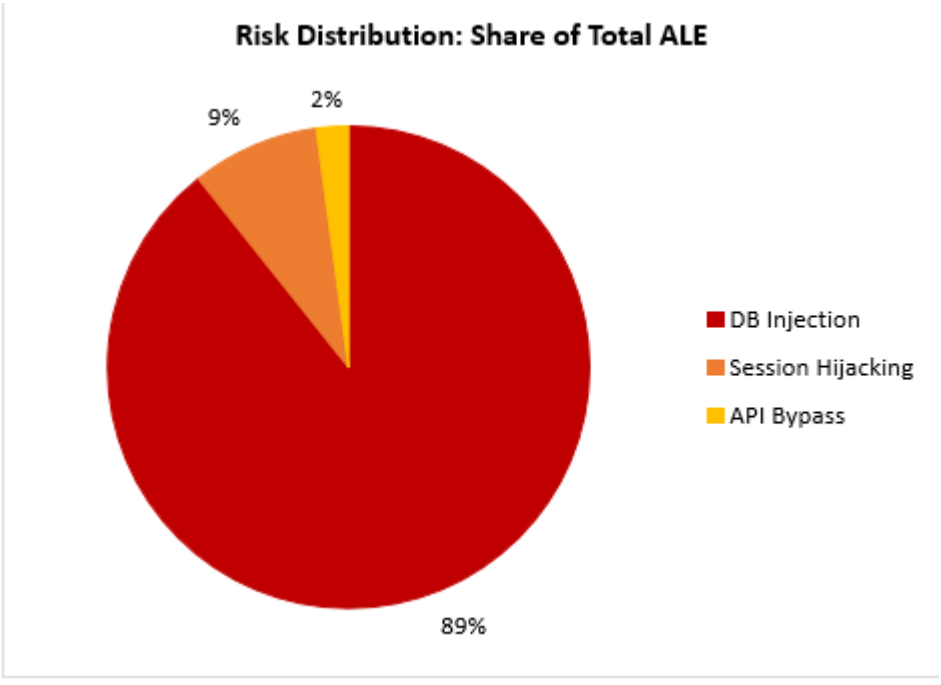
- Generate a bar chart comparing ALE for all vulnerabilities
- Create a pie chart showing risk distribution
- Develop a risk heat map (High/Medium/Low) based on probability and impact

All charts read live from Risk_Calc. Heat map cells list the vulnerabilities that fall in each probability/impact zone.

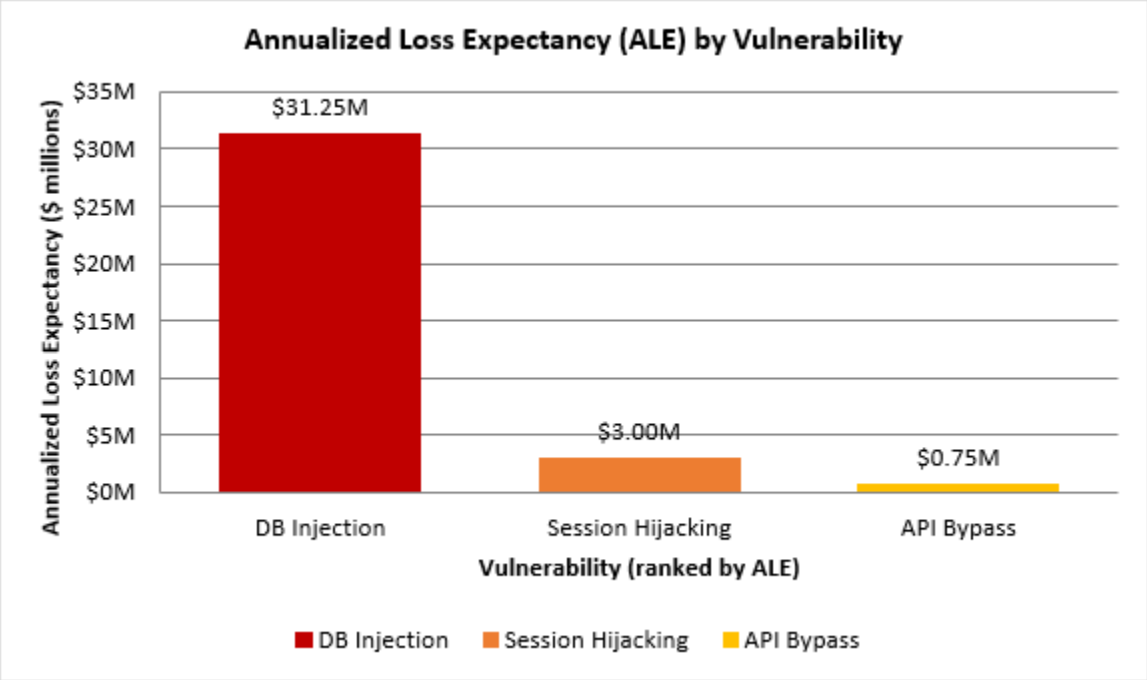
Risk Heat Map: Probability x Impact

		IMPACT (Single Loss Expectancy) >>		
PROBABILITY (annual)	**Band**	**Low**	**Medium**	**High**
Probability >= 35%	**High**		**Session Hijacking**	
20% to <35%	**Medium**			**DB Injection**
< 20%	**Low**		**API Bypass**	
		< $1.0M	*$1.0M to <$10M*	*>= $10M*
Legend:		**High**	**Medium**	**Low**

A pie chart showing risk distribution



A bar chart comparing ALE for all vulnerabilities



Phase 2: Control Evaluation

Task 4: Cost-Benefit Analysis

For each control option, calculate:

- Initial Investment
- Annual Maintenance
- Risk Reduction (in $)
- Return on Investment (ROI)
- Payback Period

Below is the step by step calculations using the WAF as the worked example first and the other two:

1. Annual risk reduction = baseline ALE × effectiveness. This is the dollar value of expected loss the control removes each year.
2. Year-1 total cost = initial investment + annual maintenance.

3. ROI (Year 1) = (annual risk reduction − Year-1 total cost) ÷ Year-1 total cost.
4. Net annual benefit = annual risk reduction − annual maintenance. Initial cost is excluded here because it's a one-time spend.
5. Payback = initial investment ÷ net annual benefit. This tells you how long the benefit takes to cover the up-front spend.

Worked example: WAF (mapped to Database Injection)

- Risk reduction: $31,250,000 × 75% = $23,437,500
- Year-1 cost: $150,000 + $25,000 = $175,000
- ROI: ($23,437,500 − $175,000) ÷ $175,000 = 132.9, or 13,293%
- Net annual benefit: $23,437,500 − $25,000 = $23,412,500
- Payback: $150,000 ÷ $23,412,500 = 0.0064 years ≈ 2.3 days
- Residual ALE: $31,250,000 − $23,437,500 = $7,812,500

For the three controls, we have:

Control	Baseline ALE	Reduction	Year-1 Cost	ROI	Payback	Residual
API Gateway (90%)	$750,000	$650,000	$400,000	69%	6.7 months	$75,000
WAF (75%)	$31,250,000	$23,437,500	$175,000	13,293%	2.3 days	$7,812,500
MFA (95%)	$3,000,000	$2,850,000	$230,000	1,139%	25.9 days	$150,000
Portfolio	$35,000,000	$26,962,500	$805,000	3,249%	9.5 days	$8,037,500

For the portfolio row, I summed up the dollar columns first and then computed ROI and payback from the totals. I did not average the three individual ROIs.

- ROI is driven by the size of the exposure, not just the cost of the control. The WAF costs less than the API Gateway but protects a $31M exposure, so its ROI is about 190 times higher. That is why the plan puts the WAF first.
- Effectiveness is not 100%. The WAF's 75% leaves $7.8M of Database Injection risk behind, which is 97% of your total residual.

Task 5: Control Selection Analysis

- Create a scatter plot showing cost vs. effectiveness of controls
- Generate a bar chart comparing ROI for all controls
- Develop a line graph showing risk reduction over time

All three are on the Control_Charts sheet of the workbook. Here is what each one shows and how it's built.

1. Scatter plot: cost vs. effectiveness

- X-axis: Year-1 total cost. Y-axis: the control's stated effectiveness.
- It plots one point per control:

Control	Year – 1- cost	Effectiveness
API Gateway	$400K	90%
WAF	$175K	75%
MFA	$230K	95%

- The takeaway is that cost and effectiveness don't move together. The most expensive control (API Gateway) is not the most effective (MFA is), and the cheapest (WAF) is the least effective. So effectiveness percentage alone can't pick the winner.

2. Bar chart: ROI comparison

- It plots Year-1 ROI for each control: WAF 13,293%, MFA 1,139%, API Gateway 69%.
- The takeaway is that the WAF wins despite having the lowest effectiveness. It is applied to a much bigger exposure ($31.25M), so 75% of that is worth far more than 95% of MFA's $3M.
- On a linear axis the API Gateway bar is very short. The data labels carry the actual numbers. I started with a log scale, but it made the smallest label unreadable, so I switched to linear.

3. Line graph: risk reduction over time

- It tracks annualized exposure across 12 months, with two lines: a flat baseline at $35.0M and a stepped-down residual line.
- The residual line steps down each time a control goes live:

Month	Event	Exposure after
0	No controls	$35.0M
1	WAF live – day 30	$11.6M
3	MFA live – day 90	$8.7M
5	API Gateway live – day 150	$8.0M

The takeaway is that almost all of the benefit arrives in month 1. The WAF alone removes $23.4M of the $27.0M total reduction, which is why it goes first.

Access Link for the Worksheet:

Lab3B_Risk_Quantification.xlsx

Phase 3: Executive Reporting

To: CISO, CFO, SecureBank Financial
From: Lead GRC Analyst
Date: 30th October 2026
Subject: SecureMobile Banking Platform: Cyber Risk Quantification

Executive Summary

The three critical findings from the penetration test carry $35.0M in annualized expected loss, and 89% of that comes from the database injection flaw. Three controls costing $700,000 up front and $105,000 per year reduce exposure by $27.0M (77%), leaving $8.0M.

Decision requested: Approve the $805,000 first-year spend and the 12-month treatment plan on page 4.

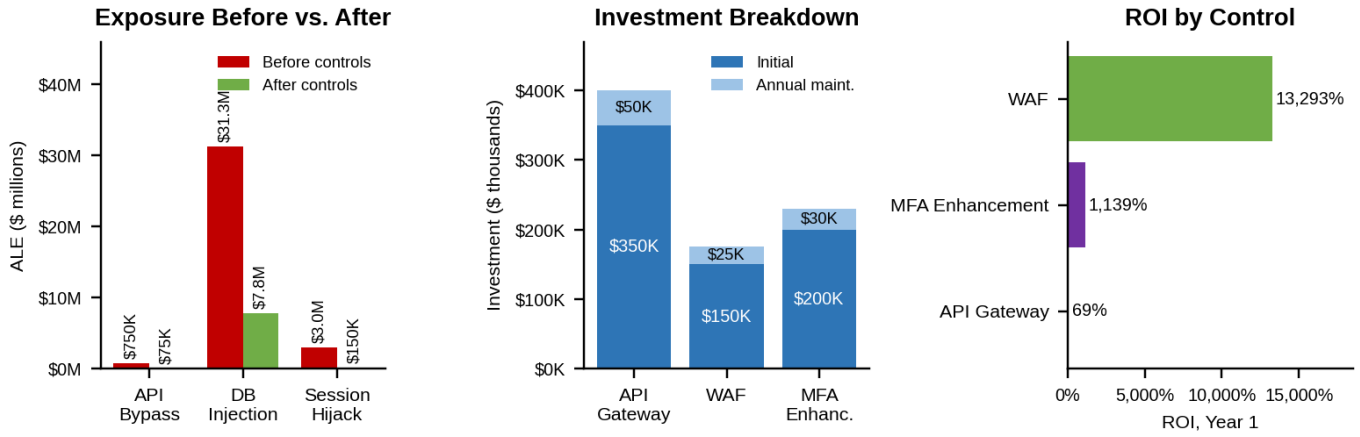
$35.0M	$8.0M	77.0%	$700K	3,249%	9.5 days
Current exposure (total ALE)	Residual after controls	Risk reduction	Initial investment	Portfolio ROI (Year 1)	Payback period

Top 3 risks

Rank	Vulnerability	ALE	% of total	Heat map	Priority
1	Database Injection Vulnerability	$31,250,000	89.3%	High	Critical
2	Session Hijacking	$3,000,000	8.6%	High	High
3	API Authentication Bypass	$750,000	2.1%	Medium	Medium

Recommended controls (in priority order)

Control	Mitigates	Initial cost	Annual maint.	Risk reduction / yr	ROI (Yr 1)	Payback
WAF	DB Injection	$150,000	$25,000	$23,437,500	13,293%	2.3 days
MFA Enhancement	Session Hijacking	$200,000	$30,000	$2,850,000	1,139%	25.9 days
API Gateway	API Bypass	$350,000	$50,000	$675,000	69%	6.7 months
Total		**$700,000**	**$105,000**	**$26,962,500**	**3,249%**	**9.5 days**



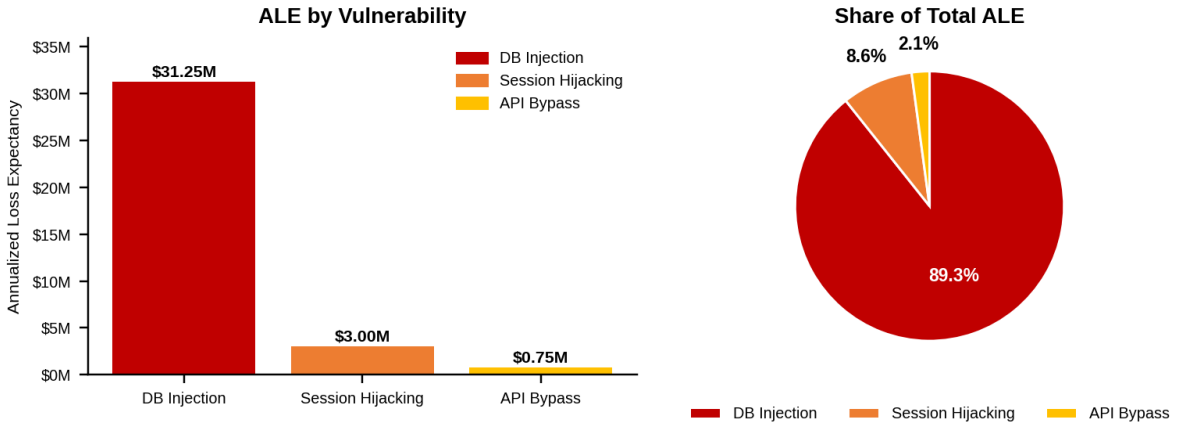
ROI (Year 1) = (annual risk reduction − initial cost − first-year maintenance) ÷ (initial cost + first-year maintenance). Estimates are modeled from the lab dataset; see Section 4 for assumptions and limits.

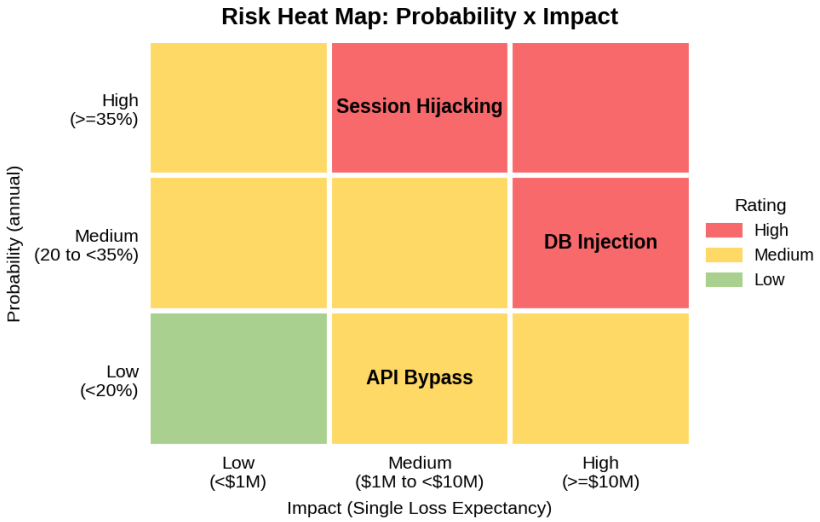
1. Risk Exposure

Each finding was quantified with the standard annualized loss method: Single Loss Expectancy (SLE) is the loss from one incident, Annual Rate of Occurrence (ARO) is the expected number of incidents per year, and Annualized Loss Expectancy (ALE) is SLE × ARO. Exploit probability is treated as the chance of one successful exploit per year, so ARO equals the stated probability.

Rank	Vulnerability	SLE basis	SLE	ARO	ALE	Priority
1	Database Injection Vulnerability	500,000 × $250 each	$125,000,000	0.25	$31,250,000	Critical
2	Session Hijacking	5,000 × $1,500 each	$7,500,000	0.40	$3,000,000	High
3	API Authentication Bypass	Given: max single-incident loss	$5,000,000	0.15	$750,000	Medium

Priority levels are set by ALE: Critical ≥ $10M, High ≥ $1M, Medium ≥ $250K, otherwise Low. These thresholds are analyst judgment and can be changed in the workbook.





What the numbers say

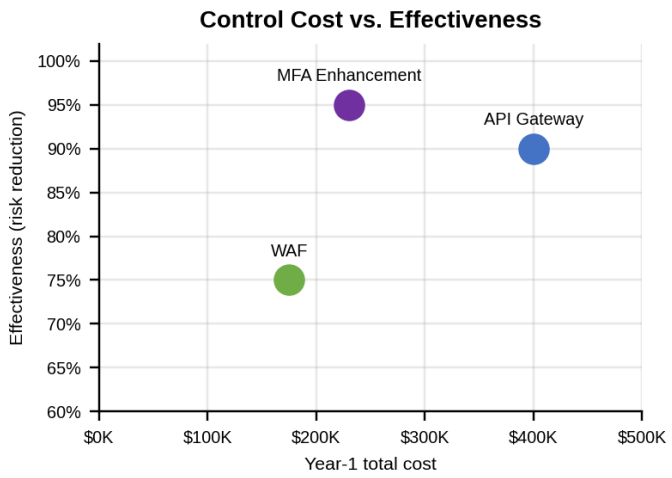
- **Database Injection Vulnerability dominates.** Its $31,250,000 ALE is 89% of total exposure, driven by the number of records at risk (500,000 profiles at $250 each).
- **Session hijacking is the most likely event** (40% per year), but its impact is far smaller, so it ranks second at $3,000,000.
- **API authentication bypass ranks lowest on ALE** ($750,000), but a single incident can reach $5M, so it stays on the plan with interim monitoring.

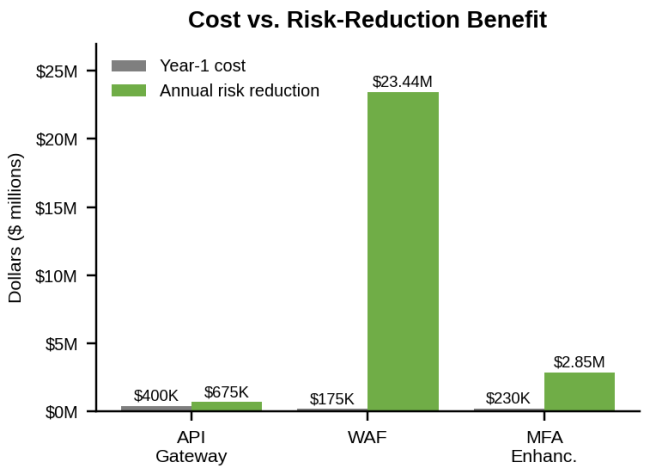
2. Control Evaluation and Financial Justification

Each control was mapped to the finding it addresses: the API Security Gateway to the API bypass, the Web Application Firewall to the database injection flaw, and MFA to session hijacking and account takeover. Risk reduction equals the baseline ALE of that finding multiplied by the control's stated effectiveness.

Control	Reduction %	Initial cost	Annual maint.	Risk reduction / yr	Net benefit / yr	ROI (Yr 1)	Payback
API Gateway	90%	$350,000	$50,000	$675,000	$625,000	69%	6.7 months
WAF	75%	$150,000	$25,000	$23,437,500	$23,412,500	13,293%	2.3 days
MFA Enhancement	95%	$200,000	$30,000	$2,850,000	$2,820,000	1,139%	25.9 days
Portfolio	**77.0%**	**$700,000**	**$105,000**	**$26,962,500**	**$26,857,500**	**3,249%**	**9.5 days**

Net benefit = risk reduction − annual maintenance. Payback = initial cost ÷ net benefit.





3-year view (undiscounted)

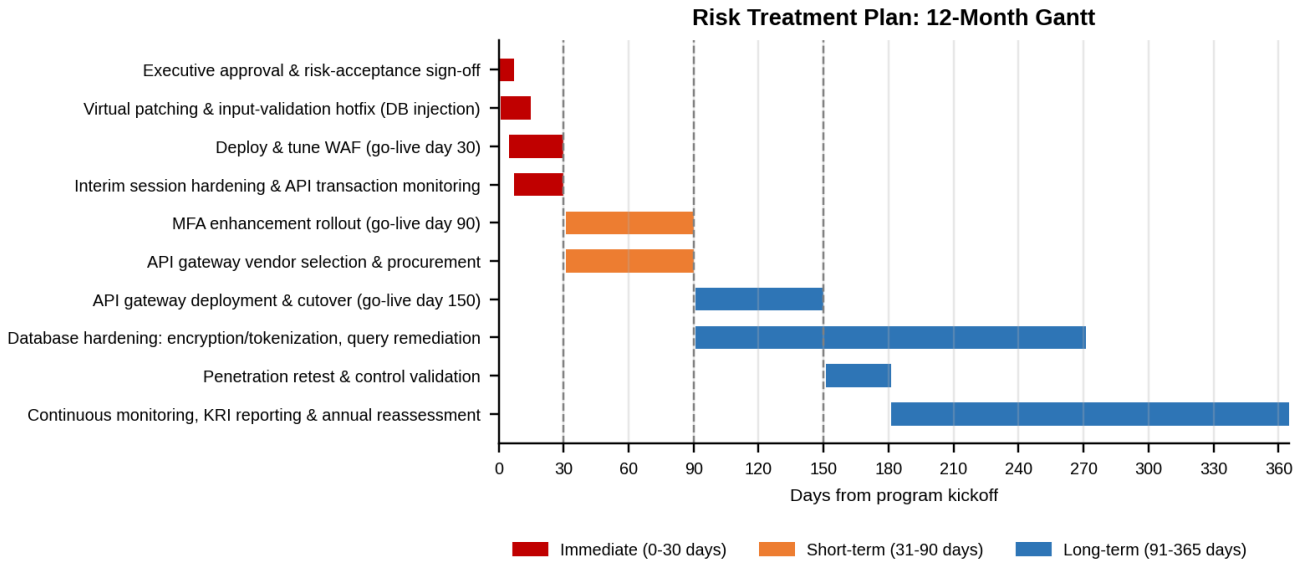
Control	Total cost	Total risk reduction	Net benefit	ROI
API Gateway	$500,000	$2,025,000	$1,525,000	305%
WAF	$225,000	$70,312,500	$70,087,500	31,150%
MFA Enhancement	$290,000	$8,550,000	$8,260,000	2,848%
Portfolio Total	**$1,015,000**	**$80,887,500**	**$79,872,500**	**7,869%**

If the budget is capped

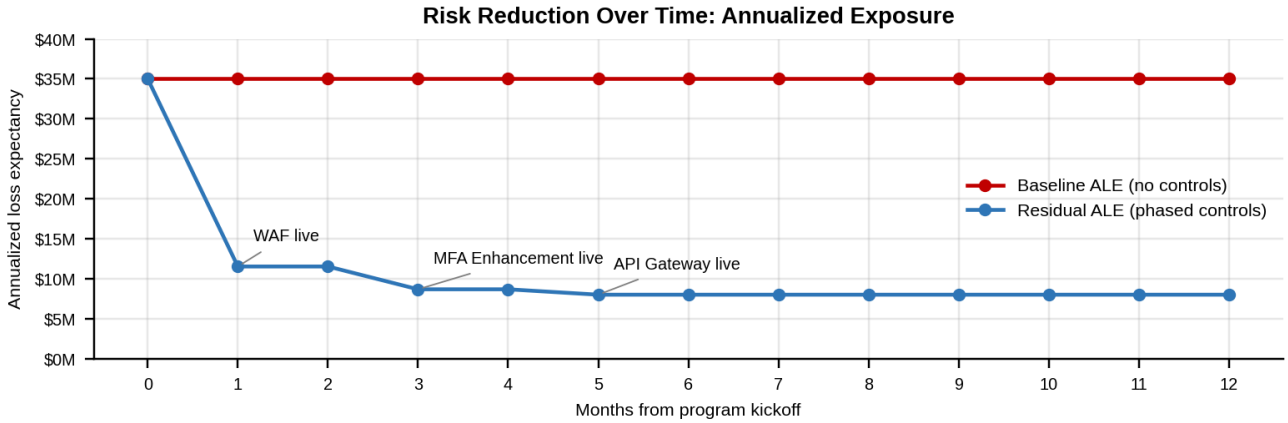
With a first-year budget of $500,000, all eight control combinations were tested. The best fit is WAF + MFA Enhancement ($405,000 in year one), which captures $26,287,500 of annual risk reduction, 97.5% of the maximum possible, and leaves $8,712,500 of residual ALE. The API Gateway would be deferred, since it delivers the smallest reduction for the largest cost.

3. Risk Treatment Plan

The plan sequences work by return: the WAF goes live first because it addresses the largest exposure at the lowest cost, MFA follows, and the API Gateway is deployed last. Immediate compensating measures cover the gaps until each control is live.



Phase	Key actions	Outcome
Immediate (days 0-30)	Executive sign-off; virtual patching and input-validation hotfix for the injection flaw; WAF deployed and tuned; interim session hardening and API transaction monitoring.	WAF live on day 30; $23.4M of annual exposure removed.
Short-term (days 31-90)	MFA enhancement rollout; API gateway vendor selection and procurement.	MFA live on day 90; a further $2.85M removed.
Long-term (days 91-365)	API gateway deployment (live day 150); database hardening (encryption or tokenization, query remediation); penetration retest; continuous monitoring and annual reassessment.	API gateway removes $675,000; exposure settles at $8.04M.



Annualized exposure falls from $35.0M to about $11.6M after the WAF goes live in month 1, to $8.7M after MFA in month 3, and to $8.0M once the API Gateway is live in month 5.

4. Assumptions, Limitation and Next Steps

Key assumptions

- Exploit probability is treated as the probability of one successful exploit per year (ARO = probability).
- The API bypass SLE is the stated maximum single-incident loss, so its ALE is an upper bound. The 48-hour detection time is context only.
- The database SLE assumes all 500,000 customer profiles are exposed in one incident at $250 per record (worst case).

- Each control reduces only the finding it is mapped to. Effectiveness applies to that finding's full ALE, from go-live, with no ramp-up and no discounting.
- Rating thresholds, go-live days and the $500K budget scenario are analyst judgment, not lab data. All are editable in the workbook.

Limitations

- **ROI and payback figures are very high because the modeled losses are large.** The WAF's 13,293% return rests on the $125M breach SLE. As an illustrative check, at one-tenth of the assumed cost per record the WAF would still return roughly 12 times its first-year cost. Treat the ROI as a ranking tool, not a forecast.
- **Residual risk is concentrated in database injection.** After controls, $7,812,500 of the $8,037,500 residual ALE (97%) remains, because the WAF is stated to reduce web vulnerabilities by 75%, not 100%.
- **Single-point inputs.** Probabilities and loss figures are point estimates from the assessment. Ranges or a Monte Carlo analysis would give the CFO a confidence interval.

Recommended next steps

1. Approve the $805,000 first-year investment ($700,000 initial plus $105,000 maintenance) and the 12-month plan.
2. Start with the WAF and the immediate hotfix, since together they address the single largest exposure within 30 days.
3. Fund database hardening (encryption or tokenization and query remediation) to attack the remaining injection risk. This is not in the control options provided, so its effect is not quantified here.
4. Retest after each go-live and report key risk indicators quarterly. Re-run this model with updated probabilities at the annual review.

All calculations are in the accompanying workbook, Lab3B_Risk_Quantification.xlsx (Assumptions, Risk_Calc, Control_Analysis, Timeline, Gantt and Bonus_Matrix sheets).

Lab3B_Risk_Quantification.xlsx